ADVISORY

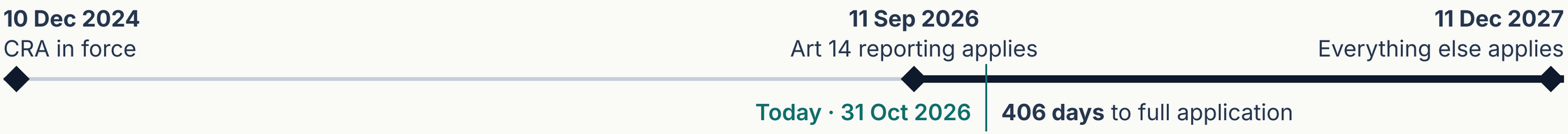
PROJECT RAMPART · ENGINEERING TRAINING

The CRA for engineers and product teams

What changes in how we design, build, ship and support products, and how everyday engineering work becomes the evidence that keeps them on sale

Facts as at 30 Oct 2026

Product security is now a condition of selling in the EU, and the clock is already running



LICENCE TO SELL

No conformity, no EU sales

From 11 Dec 2027 each product we place on the market needs a declaration and CE marking. EU revenue from the 13 in-scope families: EUR 807m (of EUR 824m).

REPORTING IS LIVE

24 hours from awareness

Since 11 Sep 2026, actively exploited vulnerabilities and severe incidents must be reported, for products already sold too.

YOUR WORK IS THE EVIDENCE

Kept for at least 10 years

Risk assessments, gate records, SBOMs and test reports make up the technical file for each product version.

Source: Regulation (EU) 2024/2847, Arts 13, 14, 69 and 71; Example Group revenue by product family; Illustrative

One regulation covers everything we ship, from devices and apps to the backends they need

SCOPE

In scope if it has a data connection

In · devices and their firmware

In · companion apps and desktop software

In · our backends a product needs to work

In · SDKs and components sold separately

Out · internal-only tools, websites, browser-only services and products with no data connection

CLASS DECIDES THE ROUTE

Four classes, four routes

Default Self-assessment under Module A	6 families
Class I · 19 categories Notified body until a standard is cited	6 families
Class II · 4 categories Always third-party assessment	1 family
Critical · 3 categories Third-party; certification once mandated	None

WHO DOES WHAT

We are the manufacturer

Engineering · the 13 Annex I product properties, SBOM and secure updates

PSIRT · vulnerability handling and 24-hour reporting

Product management · support period, user information, markets

Compliance · class, technical file, declaration and CE marking

Source: Regulation (EU) 2024/2847, Arts 2, 3, 7, 8 and 32, Annexes III–IV; scope register, 30 Oct 2026; Illustrative

Most of the change is proof: every design decision and release must leave a trail

Area	Until now	Under the CRA
Threat model	Optional, per feature, in a wiki	Signed risk assessment per product, updated on triggers
Dependencies	Added when needed	Intake gate with a due-diligence record
SBOM	On request, from the manifest	From the shipped artefact, signed, every release
Release	Tests green, tag and ship	Gate record: SBOM hash, exploit check, delta decision
Security fixes	Ride the next feature release	Separate, free, with an advisory; available for 10 years
Vulnerability reports	Whoever reads the inbox	One PSIRT process; 24-hour warning if exploited
Support	Until the next generation ships	Declared from expected use; end date shown at purchase

KEY INSIGHT

Most teams already threat-model, scan and sign. The gap is the record: per product, per version, retrievable for 10 years.

Source: Application implementation guide ss. 3–11; CRA Art 13 and Annex I; knowledge base, facts as at 30 Oct 2026

If we built the backend and the product needs it, the backend is part of the product

Remote data processing is part of the product when all three elements hold; elements 2 and 3 are decisive

01 At a distance
Public cloud, edge, on-premises or private cloud all count

02 Needed for a function
Commands, sync, onboarding, configuration, identity, updates

03 Built by or for us
Our design, or built solely to our specification; who runs it does not matter

T200 service	Function it serves	Built by	Verdict
Remote-control service	Commands from app to device	Us, on third-party IaaS	**Part of the product**
Update service	Firmware and app updates	Us	**Part of the product**
Weather API	Scheduling input	Licensed third party	Component: due diligence
Analytics telemetry	Statistics only	Us	Not part; 2(g) still applies
IaaS hypervisor	Hosting only	Cloud provider	Outside: a dependency

Source: Commission guidance C(2026) 5252 paras 184–205 (approved draft, non-binding); application guide ss. 2 and 13; Illustrative

The risk assessment decides which Annex I items apply and must justify every exclusion

T200 applicability matrix, one row per Annex I Part I item

(a)	No known exploitable vulnerabilities	Applies
(b)	Secure by default, with reset	Applies
(c)	Security updates, automatic by default	Applies
(d)	Access control and intrusion reporting	Applies
(e)	Confidentiality of data	Applies
(f)	Integrity and corruption reporting	Applies
(g)	Data minimisation	Applies
(h)	Availability and DoS resilience	Applies
(i)	Limit impact on other networks	Applies
(j)	Limit attack surfaces	Applies
(k)	Exploitation mitigation	Applies
(l)	Logging with user opt-out	Applies
(m)	**Secure erase and transfer**	**Erase only**

THREE RULES FOR THE MATRIX

Justify every exclusion. A “not applicable” row needs its reason and how residual risk is treated, such as limited intended use. T200: transfer, as no exportable data exists.

Cost is never the reason. Cost, commercial strategy and risk appetite are “not relevant”; “accepted, business decision” fails.

Keep it living. Update on a security-relevant release, a new vulnerability or threat, or a test finding. Keep every version.

Source: CRA Art 13(2)–(4), Recital 55; guidance C(2026) 5252 paras 156–163; application guide ss. 3 and 13; Illustrative

Ship clean and locked down: no known exploits, no default passwords, no open debug ports

Annex I item	Build this	Prove it with
(a) No known exploitable vulnerabilities	Release gate matching the SBOM against EUVD, NVD and CISA KEV; security updates at first use	Every finding fixed, mitigated or VEX-justified; first-use update test passes on a release unit
(b) Secure by default, with reset	No shared credentials, optional services off, onboarding that cannot be skipped, full reset	Fresh-install export shows no default account; reset leaves no data, credentials or cloud binding
(d) Access control and intrusion reporting	Authenticate every interface, cloud links included; roles, lockout, alerts on possible intrusion	Scans find no unauthenticated interface; wrong role and revoked token denied; 10 failed logins lock out
(j) Limit attack surfaces	Justify every interface in every state; lock JTAG, SWD and UART; strip debug code from releases	A debugger attach fails on a production unit; scans show only documented listeners

T200 Per-unit pairing codes printed under the faceplate · no default account · debug UART locked by fuse in production · Bluetooth pairing open only during onboarding

Source: Application guide ss. 4 and 13; ENISA Secure by Design and Default Playbook v1.0; ETSI EN 304 621 (draft)

Protect data and integrity by design: encrypt, sign, minimise and harden what we ship

Annex I item	Build this	Prove it with
(e) Confidentiality	TLS 1.3, mutual TLS for machine links, no plaintext fallback; keys in a secure element or KMS	Crypto inventory checked against a catalogue; downgrade tests fail closed; no keys in images or logs
(f) Integrity and corruption reporting	Verified boot; signed firmware, configuration and commands; corruption raises a logged event	Tampered image, configuration or command is rejected and logged; key rotation does not brick units
(g) Data minimisation	Collect only what each function needs; telemetry off by default; retention enforced in code	Default export shows telemetry off; log scan finds no personal data or secrets
(k) Exploitation mitigation	Memory-safe languages for new code; else stack protection, ASLR, W^X and CFI; sandboxed parsers	Hardening scan of the shipped binary; CI fuzzing of every external parser with no open crashes

T200 Presence data used only on the device · the cloud receives setpoints only · remote commands signed with a nonce, so replays are rejected and logged · telemetry off by default

Source: Application guide ss. 3, 4 and 13; ENISA Secure by Design and Default Playbook v1.0; ETSI EN 304 621 (draft)

Stay resilient after shipping: survive outages, log securely, erase fully, update by default

Annex I item	Build this	Prove it with
(h) Availability and DoS resilience	Essential functions keep working under load and without the backend; rate limits, watchdogs	Load test at the documented ceiling; backend-outage test with automatic recovery
(i) Limit impact on other networks	Inventory every emitter; bound outbound traffic; back-off with jitter; no amplification	Amplification factor below one; retry storms bounded in an outage test
(l) Logging with user opt-out	Structured, tamper-evident security logs with SIEM export and a documented user opt-out	Every catalogued event in a sample log; opt-out works; no personal data or secrets logged
(m) Secure erase and transfer	Permanent erase across device, app and cloud; transfer revokes the previous owner	Write-erase-read test per data type; previous owner locked out; steps in Annex II 8(d)
(c) Security updates	On by default; notice, postpone, opt-out (slide 15)	Default export shows them on; opt-out in Annex II 8(e)

T200 Local heating schedule held through a 72-hour cloud outage · log opt-out keeps update and integrity events

Source: Application guide ss. 4 and 13; ENISA Secure by Design and Default Playbook v1.0; ETSI EN 304 621 (draft)

Every release passes a security gate, and its signed record is what assessors ask for first

Gate check, before tagging any release	Evidence in the record
Threat model and matrix rows reviewed	Design review minute
Code reviewed; security changes labelled	Review approvals
SAST, fuzzing, DAST: no open critical or high	SARIF reports
SBOM from the shipped artefact, signed	SBOM SHA-512, attestation
Exploit check against EUVD, NVD and KEV	Scan output, VEX
Secure defaults; update signed, counter raised	Config export, update test log
Four security-delta questions answered	Answers, assessor, decision
Annex II, advisory and declaration decided	Annex II delta; declaration ID

Amber Gate designed, not yet enforced; the T200 is the pilot product

GATE RECORD, PER RELEASE

```
{
 "release": "t200-fw-2.4.1",
 "sbom_sha512": "1a7e…c03b",
 "exploit_check": "pass",
 "vex": "V-031",
 "defaults": "FC-09 match",
 "delta": "no,no,no,no",
 "substantial": false,
 "declaration": "existing",
 "signed_by": [
   "release manager",
   "product security"]
}
```

Source: Application guide ss. 5, 12 and 13; workstream status, SteerCo #1, 30 Oct 2026; record shown is illustrative

Ship nothing with a known exploitable vulnerability: match the SBOM, then decide every finding

01 Match
Every SBOM component against EUVD, NVD and CISA KEV, within 24 hours of the gate

02 Check reachability
Is the vulnerable code compiled in, reachable and actually exploited here?

03 Decide each finding
Patch, publish a mitigation, block the release, or record VEX “not_affected”

04 Recheck at first use
Units from stock install security updates before onboarding completes

THE GATE CHECK IN CI (ILLUSTRATIVE)

```
grype sbom:sbom.cdx.json --fail-on high \
  && ./kev-check.sh sbom.cdx.json kev.json
```

Fails the release on a high-severity finding or a KEV match; the scan output and VEX go into the gate record.

T200 · TLS LIBRARY CVE

Listed in EUVD at release-candidate time. The vulnerable function is excluded by build flags, so the gate records VEX V-031 “not_affected” with that justification and schedules the upgrade for the next security release. The same VEX shows no Article 14 report was due.

Source: Guidance C(2026) 5252 paras 218 and 233–237 (approved draft); application guide ss. 3–5; ETSI EN 304 626 (draft); Illustrative

Four questions decide whether a release is a new product with its own declaration

Security-delta assessment, answered and recorded at every release gate: does the change bring…

Q1	Q2	Q3	Q4
New threat vectors?	**New attack scenarios?**	**Changed likelihood?**	**Changed impact?**

FOUR ANSWERS “NO”

Not substantial: same declaration

Security updates that reduce risk, even large ones

Features already foreseen in the risk assessment

T200 firmware 2.4.1: replay fix, four “no” answers

ANY ANSWER “YES”

Assess: it may be a new placing

If substantial: new declaration and support period

A “remember me” token or unencrypted log export

Firmware adding new connectivity or remote control

Source: Guidance C(2026) 5252 paras 103–112, Examples 40–48 (approved draft); application guide ss. 5, 12 and 13; Illustrative

Generate the SBOM from what we ship, sign it, and keep vulnerability data out of it

01 Build
Compile or assemble the image

02 Generate
From the artefact: Yocto, Syft, cdxgen

03 Enrich
BSI fields: SHA-512, licence, completeness

04 Validate
Schema check and sbomqs score gate

05 Sign, store
cosign attestation; monitored with an EUVD watch

WHAT GOES IN

Per component: name, version, creator, filename, SHA-512 hash, licence and dependencies with completeness marked. CycloneDX 1.6+ or SPDX 3.0.1+.

WHAT STAYS OUT

Vulnerability status: the SBOM is static inventory, and status lives in VEX and CSAF. It sits in the technical file and need not be published.

K07 · SIGNED SBOMS

38% Red

9 of 24 releases in the last 30 days; target 100% by 31 Mar 2027

Source: BSI TR-03183-2 v2.1.0 (non-binding); CRA Annex I Part II(1), Recital 77; KPI K07, 30 Oct 2026; Illustrative

Treat open-source components as suppliers we cannot contract with

Component intake gate: the due-diligence record, Art 13(5)

Field	What to record
Need	Function we use and security properties we rely on
Maintenance	Cadence, fix times, maintainers, OpenSSF Scorecard
Licence	SPDX identifier; duties when we share fixes upstream
Vulnerability history	EUVD, NVD and OSV entries; fixes in supported branches
Support horizon	Upstream end of life against our support period
Exit plan	Replacements, effort to swap, isolation if it stays
Decision	Approved, with conditions or rejected; owner and date

Survey: 51% of manufacturers rely passively on upstream projects for security fixes; integrating never transfers our duty.

FOUND A BUG IN A COMPONENT?

1 · Check it is not already known: databases, advisories, issue tracker

2 · Report the version we integrate through the maintainer's disclosure channel, Art 13(6)

3 · Share our fix as a licence-compatible patch, machine-readable where appropriate

4 · Log it in the PSIRT case; carry the patch on a vendor branch named by CVE

No duty that the fix is merged; with no maintainer, the product duty stays ours alone.

Source: CRA Art 13(5)–(6); guidance paras 222–229; Linux Foundation 2026 (survey, manufacturer module n = 194–219)

Engineer the update path like a product: it keeps every other requirement true after shipment

01 Sign
Offline root and online key in an HSM; duties separated

02 Publish
TUF-style metadata: version, expiry, monotonic counter

03 Verify
Signature, applicability, freshness; reject older versions

04 Install
Atomic A/B slots; power loss never bricks a unit

05 Record
Outcome logged per unit; recovery image kept

WHAT USERS GET

Automatic by default for consumer products, with notice, a bounded postpone and a clear opt-out, Annex II 8(e)

Security fixes on their own train, free of charge and each with an advisory message

Each update available for at least 10 years after issue, or the rest of the support period if longer

T200 AND THE PROGRAMME

T200: TUF roles, A/B slots, monotonic counter; in-app postpone up to 7 days; installers set maintenance windows

Repository on immutable storage, budgeted for 10 years after the last release

Milestone M10: HSM signing and anti-rollback hardened by 30 Jun 2027

Source: CRA Annex I, Art 13(9); ENISA secure-update advisory v0.1 (draft); application guide ss. 7 and 13; plan of record; Illustrative

Make us easy to report to: three intake routes, one PSIRT process, a public advisory

```
# https://www.example.com/.well-known/security.txt (RFC 9116, signed with the PSIRT key)
Contact: mailto:psirt@example.com
Contact: https://www.example.com/security/report
Expires: 2027-10-01T00:00:00.000Z
Encryption: https://www.example.com/security/psirt-pgp.asc
Policy: https://www.example.com/security/cvd-policy
CSAF: https://www.example.com/.well-known/csaf/provider-metadata.json
```

01 Intake
security.txt, anonymous web form, human channel; component reports too

02 Triage
A case per report: UTC times, reachability, CVSS, exploitation check

03 Remediate
Risk-based: a security update, a mitigation or documentation

04 Disclose
Once fixed: advisory and CSAF 2.0 with CVE and EUVD IDs

Targets (BSI figures, not law): human response within 5 working days · detailed feedback within 10 · disclosure by default within 90 days

Source: CRA Annex I Part II(4)–(6), Art 13(17); RFC 9116; BSI TR-03183-3 (non-binding); ENISA SME kit (consultation draft)

If you suspect active exploitation, call PSIRT within the hour: do not wait for certainty

⚠ THE FIRST HOUR

1 · Call PSIRT on-call: [PSIRT on-call number]

2 · Preserve evidence: logs, dumps, telemetry, affected units

3 · Write times in UTC: what you saw, when, who you told

4 · Do not wait for certainty: the incident commander decides

5 · Do not disclose: no public tickets, posts or emails

Our first drill, on 22 Oct 2026, filed the early warning in **9h 40m**.

THE CLOCKS RUN FROM AWARENESS

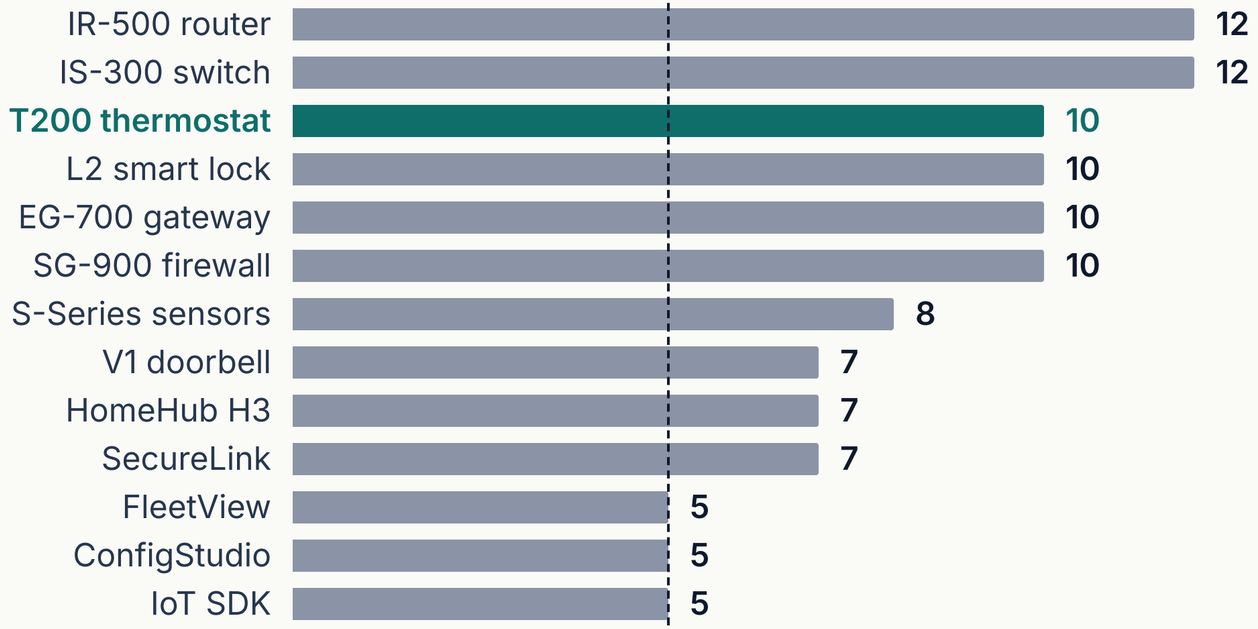
24h	**Early warning** Product, versions, Member States, UTC time
72h	**Notification** Measures taken, user actions; legal review
14 days	**Final report** After a fix or mitigation is available

Severe incident: same 24h and 72h, final report 1 month after the notification. All filed on ENISA's Single Reporting Platform.

Source: CRA Art 3(42), Art 14(2), (4) and (7); guidance C(2026) 5252 para 213; drill record, 22 Oct 2026; Illustrative

Our declared support periods run from five to twelve years, and buyers must see the end date

Declared support period by product family, years; dashed line: five-year floor



SO WHAT

Set it from expected use. Five years is a floor, not a default.

Show the end month and year at purchase: product, packaging or online.

Per variant and version: each substantially modified software version gets its own.

Source: CRA Art 13(8) and (19); guidance C(2026) 5252 paras 125–135; Example Group scope register, 30 Oct 2026; Illustrative

The technical file is assembled from what engineering already produces, if CI captures it

Annex VII point	What engineering supplies	Captured from
1 · General description	Intended purpose, versions, photos, user information	Product definition record
2(a) · Design	Architecture, interfaces, controls per Annex I item	Design review records
2(b) · Vulnerability handling	SBOM, CVD policy, update design note	Signed SBOM; PSIRT records
2(c) · Production	Build, signing and release process	**Gate record per release**
3 · Risk assessment	Threat model, applicability matrix, change log	Versioned assessment
4 · Support period	Rationale and version-support register	Product management records
5 · Standards applied	Standards or drafts used, labelled as drafts	Compliance lead
6 · Test reports	Product and process tests, indexed by requirement	SARIF and test logs from CI
7, 8 · Declaration, SBOM	Declaration copy; SBOM on reasoned request	Compliance; artefact store

Kept 10 years after placing on the market or for the support period, whichever is longer · documentation readiness today: 24%

Source: CRA Annex VII and Art 13(13); application guide ss. 5, 11 and 12; readiness diagnostic, 28 Oct 2026; Illustrative

The T200 shows the whole chain: one evidence trail from product boundary to declaration

01 · BOUNDARY
Device, two apps, control and update services; weather API is a component

02 · CLASS AND ROUTE
No Annex III match: default class, Module A; re-check if a camera is added

03 · RISK
BSI TR-03183-1 with STRIDE; every item applies except transfer under (m)

04 · CONTROLS
Per-unit codes, fused UART, signed commands, local heating if the cloud fails

05 · RELEASE
SAST, parser fuzzing, API DAST; 2.4.1 shipped under the existing declaration

06 · SBOM, UPDATES
Yocto, cdxgen and Syft SBOMs, signed and monitored; TUF and A/B slots

07 · REPORTING
Replay flaw: probing only, no Art 14 report; fix shipped with a CSAF advisory

08 · DOCUMENTATION
One family file, Annex II at a versioned URL, Module A record, declaration

STATUS Reference walk-through, not today’s status: T200 readiness is 46% and its risk assessment is in review

Source: Application guide s. 13 (reference walk-through); readiness diagnostic, 28 Oct 2026; KPI K08, 30 Oct 2026; Illustrative

Ten mistakes early adopters keep making, each with the countermeasure that prevents it

01 **SBOM built from the manifest**
Generate it from the shipped artefact; add binary scanning

02 **Scanner hits treated as active exploitation**
Reachability first, VEX recorded; Art 14 needs real evidence

03 **Default credentials shipped for convenience**
Per-unit secrets; force credential set-up at first use

04 **Debug ports left open on production units**
Lock JTAG, SWD and UART; prove it with a debugger attach

05 **Telemetry on by default “for product improvement”**
Inventory data, make it opt-in, record the 2(g) justification

06 **A logging opt-out that kills security events**
Document which events persist, and why, in Annex II

07 **Signed updates without anti-rollback**
Monotonic counter; only authorised, audited downgrades

08 **Security fixes bundled into feature releases**
Maintenance branches with a security-only channel

09 **Evidence assembled by hand when someone asks**
Emit gate records, hashes and test results from CI

10 **Our backend left out because “it is cloud”**
Apply the three-element test; assess both ends of each link

Source: Application guide s. 14; Commission FAQ v1.4; BSI TR-03183-2; vendor material (Finite State, OmniTrust), unverified

Check your understanding: five questions, two minutes

Q1	**Which T200 service is part of the product as remote data processing?**	**A** Our remote-control service	**B** The licensed weather API
		C Both services	**D** Neither: cloud is out of scope
Q2	**Which is not a valid reason to accept a residual risk?**	**A** Physical access, documented	**B** Vulnerable code not compiled in
		C The fix is too costly this year	**D** Use limited by intended purpose
Q3	**What belongs in the SBOM for each component?**	**A** Its current CVE status	**B** CVSS scores of open findings
		C Only code we wrote ourselves	**D** Name, version, hash, licence
Q4	**When does the 24-hour early-warning clock start?**	**A** When the first report arrives	**B** When a CVE is published
		C Reasonable certainty of exploitation	**D** When a fix is available
Q5	**A security-only release answers “no” to all four delta questions. What follows?**	**A** A new declaration of conformity	**B** Ship under the existing declaration
		C A new notified-body assessment	**D** The support period restarts

Vote A–D on each question or note your answers; the trainer reveals them from the speaker notes

Ask early, through these routes rather than a private inbox

URGENT · WITHIN THE HOUR

PSIRT on-call, 24/7: [PSIRT on-call number]

PSIRT mailbox: [PSIRT mailbox]

For any vulnerability report or sign of exploitation

READ AND PRACTISE

Engineering Compliance Knowledge Base and its implementation guide

CRA Readiness Diagnostic (D08) for your product

Programme channel: [programme channel]

Who to ask about what	Role
Risk assessment, release gate, Annex I patterns	Product security officer
SBOM pipeline, signing, binary scanning	Head of platform engineering
Classification, technical file, declaration	Compliance lead
Reporting, drills, CVD policy and security.txt	PSIRT lead
Support periods, user information, distribution map	Product management
Training, the LMS module and team sessions	Head of engineering enablement

Contacts in square brackets are placeholders, confirmed by the PSIRT lead before rollout; roles per the programme plan

Five things to take back to your backlog today

01 **Reporting is already law**
Suspect active exploitation? Call PSIRT within the hour; the 24 hours run from awareness

02 **Our backend is part of the product**
If we built it and the product needs it, assess it, including both ends of every remote link

03 **The risk assessment drives Annex I**
Thirteen items, a justification for every exclusion, and cost is never the reason

04 **Evidence comes from the pipeline**
An SBOM from the shipped artefact, signed, and a gate record for every release

05 **Ship secure, keep it secure**
Secure defaults, signed updates with anti-rollback, separate free fixes, a declared support period

406 days from 31 Oct 2026 to full application on 11 Dec 2027 · questions to the Project Rampart channel